



Vulnerability Assessment &
Penetration Testing (VAPT) Report

Unity Health (PTY) Ltd

08 June 2022



TABLE OF CONTENTS

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP.....	3
3.2	NESSUS	3
3.3	GREENBONE ENTERPRISE	4
	STAY ONE STEP AHEAD OF ATTACKERS.....	4
3.4	OWASP.....	5
3.5	BRUTE FORCE	5
4	VIRTUAL SERVERS	6
4.1	PRODUCTION SERVER	6
4.2	TEST SERVER.....	8
4.3	VP SERVER.....	10
5	REPORTING CONCLUSION	11
6	AUDITORS	11



1 EXECUTIVE SUMMARY

The purpose of this assessment was to point out security loopholes, business logic errors, and missing best security practices. The tests were carried out assuming the identity of an attacker or a malicious user but, no harm was made to the functionality or working of the application / network. A full scan was also performed on the infrastructure to demonstrate a known attack, i.e. someone on the internal network or same public subnetted infrastructure. The scans and brute force were performed over 15 (fifteen) business days, as full and slow comprehensive audits were performed. These types of scans also look at unknown connectivity options, including packet SYN requests.

The overall results will be published below, High-level, Sautech is comfortable and happy with the results. Some recommendations however, is offered and also mentioned throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Server hosted at Afrihost that is behind a managed CheckPoint Firewall
- 3 (Three) x Hosted Virtual Servers namely:
 - Production = 41.76.215.242
 - Test = 41.76.215.103
 - VP Server = 41.76.215.27

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

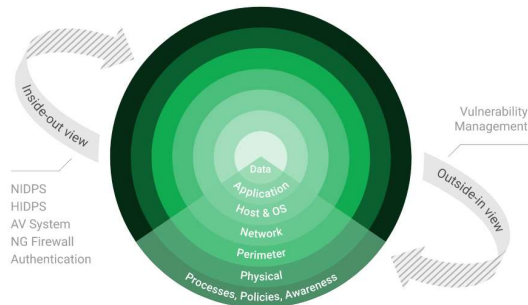
3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.



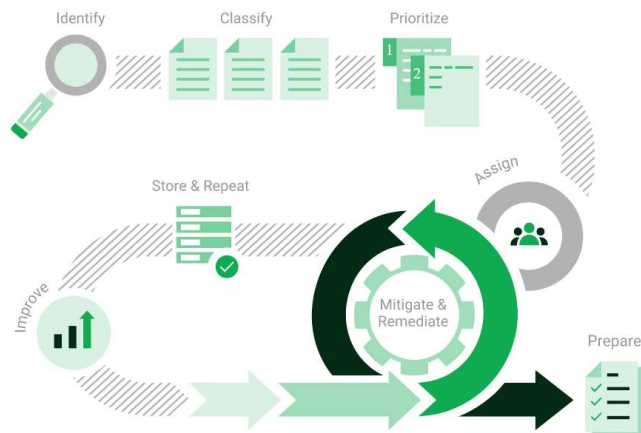
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



Stay One Step Ahead of Attackers

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.

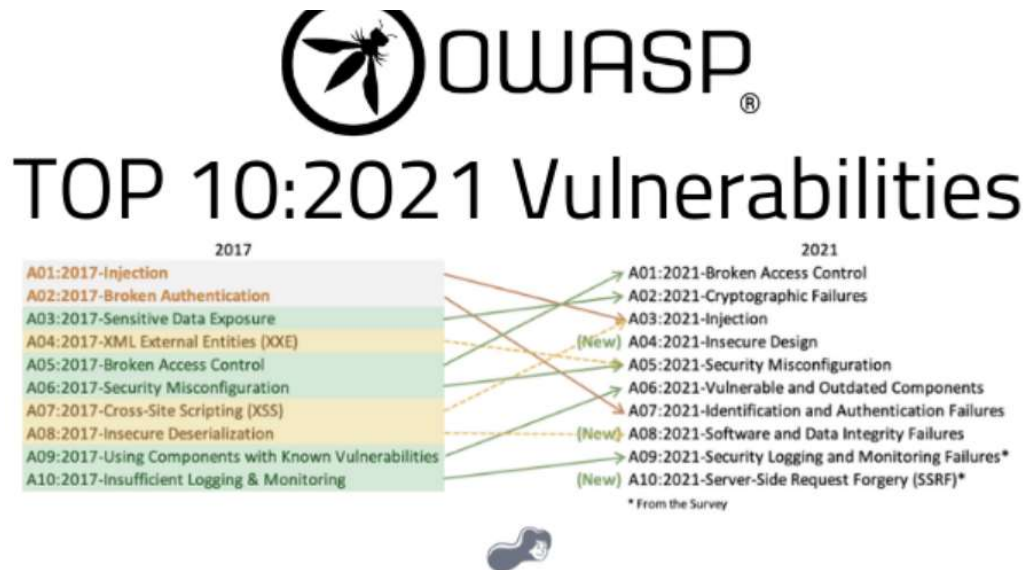


The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.



3.4 OWASP

The **Open Web Application Security Project (OWASP)** is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



3.5 BRUTE FORCE

- A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.
- The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts. Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers



3.6 Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 1 Million + Username and password combos are used to Brute force application like RDP, SSH etc.

```
[STATUS] 25.93 tries/min, 20408 tries in 13:07h, 61 to do in 00:03h, 4 active
[STATUS] 25.93 tries/min, 20431 tries in 13:08h, 38 to do in 00:02h, 4 active
[STATUS] 25.93 tries/min, 20455 tries in 13:09h, 14 to do in 00:01h, 4 active
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-06-07 02:59
31
(root@kali)-[/usr/share/wordlists/dirb]
```

4 VIRTUAL SERVERS

4.1 Production Server

We have performed three types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.
- Bruce Force Attacks.

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

```
Nmap Scan Report - Scanned at Mon Jun 6 11:52:27 2022

Scan Summary | ambledownhost1.dedicated.co.za (41.76.215.242)

Scan Summary
Nmap 7.92 was initiated at Mon Jun 6 11:52:27 2022 with these arguments:
nmap -sS -sU -T4 -A -v -PE -PP -PS80,443 -PA3389 -PU40125 -PY -g 53 --script "default or (discovery and safe)" 41.76.215.242
Verbosity: 1; Debug level 0

41.76.215.242 / ambledownhost1.dedicated.co.za
```



Ports

The 1956 ports scanned but not shown below are in state: **closed**

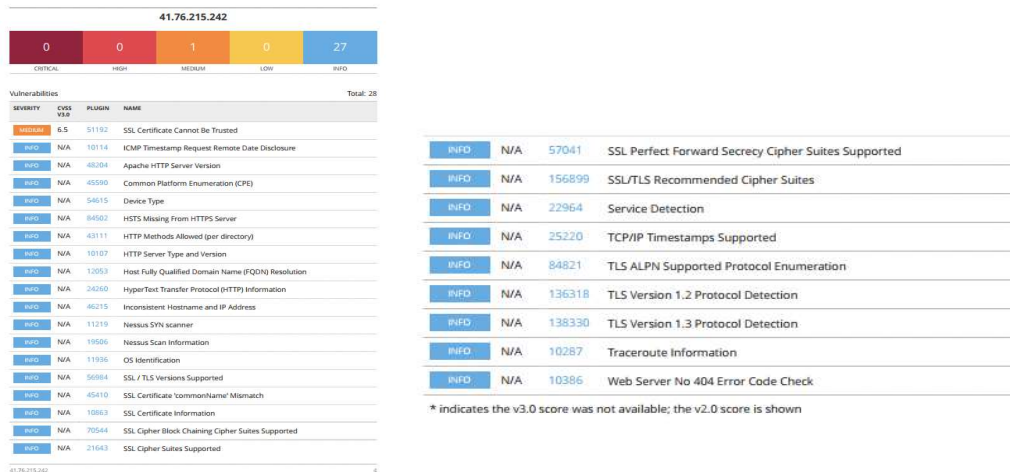
Port	State (toggle closed [0] filtered [5])	Service	Reason	Product	Version	Extra info
22	tcp open	ssh	syn-ack	OpenSSH	8.0	protocol 2.0
111	tcp open	rpcbind	syn-ack		2-4	RPC #100000
139	tcp open	netbios-ssn	syn-ack	Samba smbd		
445	tcp open	netbios-ssn	syn-ack	Samba smbd		
1025	tcp open	NFS-or-IIS	syn-ack			
1026	tcp open	LSA-or-nterm	syn-ack			
1027	tcp open	IIS	syn-ack			
1028	tcp open	unknown	syn-ack			
1029	tcp open	ms-lsa	syn-ack			
1030	tcp open	iad1	syn-ack			
1031	tcp open	iad2	syn-ack			
1720	tcp open	h323q931	syn-ack			
5432	tcp open	postgresql	syn-ack	PostgreSQL DB	9.6.0 or later	
5901	tcp open	vnc	syn-ack	VNC		protocol 3.8
5902	tcp open	vnc	syn-ack	VNC		protocol 3.8
6001	tcp open	X11:1	syn-ack			
8080	tcp open	http	syn-ack	Apache Tomcat	9.0.62	
9080	tcp open	http	syn-ack	Apache Tomcat/Coyote JSP engine	1.1	
9090	tcp open	http	syn-ack	Jetty	9.4.14.v20181114	
33899	tcp open	java-rmi	syn-ack	Java RMI		

Remote Operating System Detection

- Used port: **22/tcp (open)**
- Used port: **1/tcp (closed)**
- Used port: **2/udp (closed)**
- OS match: **Linux 3.10 - 3.12 (91%)**
- OS match: **Linux 4.4 (91%)**
- OS match: **Linux 4.9 (90%)**
- OS match: **Linux 4.0 (88%)**
- OS match: **Linux 3.10 (88%)**
- OS match: **Linux 3.10 - 3.16 (88%)**
- OS match: **Linux 3.11 - 4.1 (87%)**
- OS match: **Linux 2.6.32 (87%)**
- OS match: **Linux 2.6.32 or 3.10 (87%)**
- OS match: **Linux 2.6.39 (87%)**

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



Details: Plugin 51192 fires on hosts that have an untrusted SSL certificate- this commonly means **the certificate is either expired, self-signed, or signed by an 'unknown' authority**. The output of plugin 51192 will include the certificate details, as well as which port and service it was detected on.

Vendor security updates are not trusted. Based on the above results, a specific attack was launched against the affected machine. These are all in separate documents for ease of reference to this report



iii) Brute Force

Randomised usernames with a word list containing more than 1+ million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
root@kali: /usr/share/wordlists/dirb
(root@kali)-[/usr/share/wordlists/dirb]
_
(root@kali)-[/usr/share/wordlists/dirb]
_
$ hydra -l mip -P /usr/share/wordlists/dirb/big.txt 41.76.215.242 -t 4 ssh
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-06-06 13:49:
06
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20469 login tries (l:1/p:20469
), ~5118 tries per task
[DATA] attacking ssh://41.76.215.242:22/
[STATUS] 40.00 tries/min, 40 tries in 00:01h, 20429 to do in 08:31h, 4 active
[STATUS] 28.00 tries/min, 84 tries in 00:03h, 20385 to do in 12:09h, 4 active
[STATUS] 26.29 tries/min, 184 tries in 00:07h, 20285 to do in 12:52h, 4 active
[STATUS] 26.93 tries/min, 404 tries in 00:15h, 20065 to do in 12:25h, 4 active
[STATUS] 26.06 tries/min, 808 tries in 00:31h, 19661 to do in 12:35h, 4 active
[STATUS] 26.04 tries/min, 1224 tries in 00:47h, 19245 to do in 12:19h, 4 active
[STATUS] 26.10 tries/min, 1644 tries in 01:03h, 18825 to do in 12:02h, 4 active
```

4.2 Test Server

We have performed three types of scans/attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter but also include local network.
- Vulnerability assessments
- Bruce Force Attacks

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

```
Nmap Scan Report - Scanned at Mon Jun 6 09:29:56 2022

Scan Summary | ambledownhost2.dedicated.co.za (41.76.215.103)

Scan Summary

Nmap 7.92 was initiated at Mon Jun 6 09:29:56 2022 with these arguments:
nmap -sS -sU -T4 -A -v -P -PE -PS80,443 -PA3389 -PU40125 -PY -g 53 --script "default or (discovery and safe)" 41.76.215.103
Verbosity: 1; Debug level 0

41.76.215.103 / ambledownhost2.dedicated.co.za
```




Ports

The 1969 ports scanned but not shown below are in state: **closed**

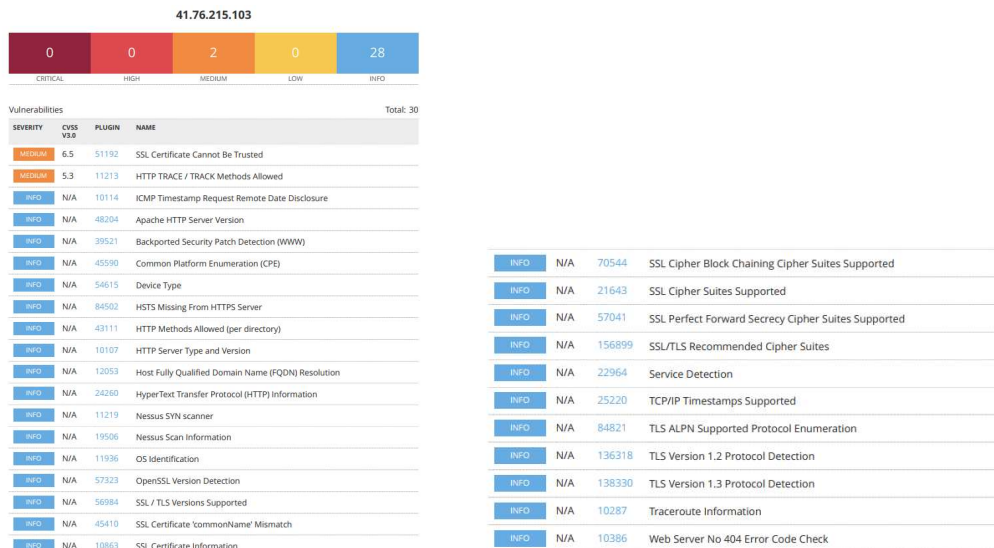
Port	State (toggle closed [0] filtered [5])	Service	Reason	Product	Version	Extra info
22	tcp open	ssh	syn-ack	OpenSSH	8.0	protocol 2.0
111	tcp open	rpcbind	syn-ack		2-4	RPC #100000
139	tcp open	netbios-ssn	syn-ack	Samba smbd		
445	tcp open	netbios-ssn	syn-ack	Samba smbd		
1720	tcp open	h323q931	syn-ack			
3000	tcp open	http	syn-ack	Node.js		Express middleware
8080	tcp open	http	syn-ack	Apache Tomcat	9.0.62	
9090	tcp open	http	syn-ack	Jetty	9.4.14.v20181114	

Remote Operating System Detection

- Used port: **22/tcp (open)**
- Used port: **1/tcp (closed)**
- Used port: **2/udp (closed)**
- OS match: **Linux 3.10 - 3.12 (91%)**
- OS match: **Linux 4.4 (91%)**
- OS match: **Linux 4.9 (90%)**
- OS match: **Linux 3.10 (88%)**
- OS match: **Linux 4.0 (87%)**
- OS match: **Linux 3.11 - 4.1 (87%)**
- OS match: **Linux 2.6.32 (87%)**
- OS match: **Linux 2.6.32 or 3.10 (87%)**
- OS match: **Linux 2.6.39 (87%)**
- OS match: **WatchGuard Firewall 11.8 (87%)**

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:



Plugin 11213: Disabling TRACE and TRACK in Apache for PCI-related vulnerabilities like **Web Server HTTP Trace/Track Method Support Cross-Site Tracing Vulnerability** is surprisingly quite easy with the Apache web server. The main thing to keep in mind is understanding that if you are running apache and this vulnerability pops up during a scan, you can be reasonably certain that TRACK is not the problem—TRACE is.

The HTTP TRACK method is something Microsoft cooked up that performs essentially the same thing that TRACE does with the exception that it never got used—except by penetration testers, hackers, worms, and vulnerability scanners.



4.3 VP Server

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

Nmap Scan Report - Scanned at Mon Jun 6 11:24:41 2022

Scan Summary | jetwebvm.dedicated.co.za (41.76.215.27)

Scan Summary

Nmap 7.92 was initiated at Mon Jun 6 11:24:41 2022 with these arguments:
`nmap -sS -sU -T4 -A -v -PE -PP -PS80,443 -PA3389 -PU40125 -PY -g 53 --script "default or (discovery and safe)" 41.76.215.27`
Verbosity: 1; Debug level 0

41.76.215.27 / jetwebvm.dedicated.co.za

Ports

The 1974 ports scanned but not shown below are in state: **closed**

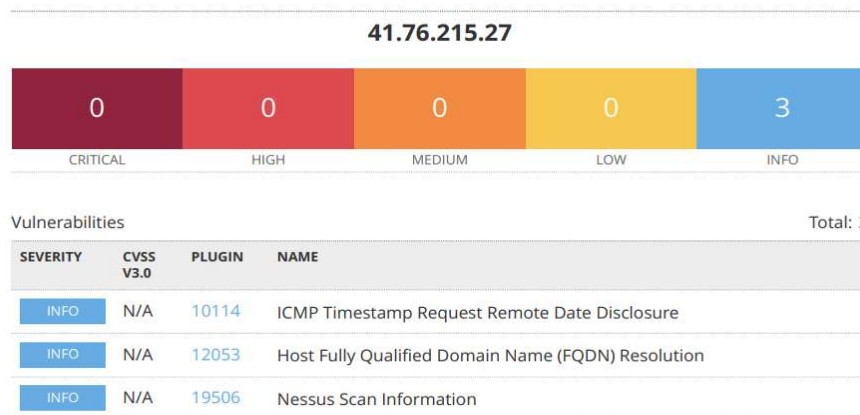
Port	State (toggle closed [0] filtered [5])	Service	Reason	Product	Version	Extra info
22	tcp open	ssh	syn-ack	OpenSSH	8.0	protocol 2.0
1720	tcp open	h323q931	syn-ack			

Remote Operating System Detection

- Used port: 22/tcp (open)
- Used port: 1/tcp (closed)
- Used port: 2/udp (closed)
- OS match: Linux 4.4 (91%)
- OS match: Linux 3.10 - 3.12 (90%)
- OS match: Linux 4.9 (89%)
- OS match: Linux 4.0 (88%)
- OS match: Linux 3.10 - 3.16 (88%)
- OS match: Linux 3.11 - 4.1 (87%)
- OS match: Linux 2.6.32 (87%)
- OS match: Linux 2.6.32 or 3.10 (87%)
- OS match: Linux 3.4 (87%)
- OS match: Linux 3.5 (87%)

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:





5 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view that from External Testing where the SSH port are not open to public, these vulnerabilities then become academic. However, we still recommend that the changes be implemented. As Unity Health is behind the managed checkpoint Firewall, not even the local subnetted public network can exploit the SSH vulnerabilities.

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a Hosted Infrastructure point of view, we are happy with the results. We do recommend that SentinelOne is implemented into the production environment as soon as possible.

Six addendum reports are attached to this report and should be read as one document.

With the following test performed:

- Network scanning
- IDS/IPS disabled
- Knows network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports i.e.: ssh open

Sautech concludes that best practise methodologies and technologies are used inside and supporting the hosted Unity Health Infrastructure.

6 AUDITORS

These audits were concluded over a period of 15 days.
We hereby confirm that the above information is true and correct:

08th June 2022 – Krugersdorp, South Africa

Riaan van Jaarsveld
Security Expert – CCSA

Lukas Janse van Rensburg
Security Engineer